

Email Security and Deliverability Configuration

Microsoft 365 / Exchange Online

Prepared by [Olu Adelokiki](#) | [LinkedIn](#)

Table of Contents

1. Name	2
2. Purpose	2
3. Scope	2
4. Configuration Details	2
4.1 Email Authentication Protocols (Anti-Spoofing)	2
SPF (Sender Policy Framework)	2
DKIM (DomainKeys Identified Mail)	2
DMARC (Domain-Based Message Authentication, Reporting, and Conformance)	3
4.2 Microsoft Defender for Office 365	3
Plan Comparison	3
Threat Policies Configured	4
4.3 External Email Tagging	4
4.4 Identity and Access Hardening (Entra ID)	4
Conditional Access Policies	4
Risk-Based Access Policies (Requires Entra ID P2)	5
4.5 Logs, SIEMs, and Alerts	5
4.6 User Awareness and Incident Response	5
5. Dependencies	5
6. Impact	6
7. Risks and Considerations	6
8. Notes	6

1. Name

Email Security and Deliverability Configuration — Microsoft 365 / Exchange Online

2. Purpose

Establish a layered email security posture for a Microsoft 365 tenant by configuring email authentication protocols (SPF, DKIM, DMARC), Microsoft Defender for Office 365 threat policies, identity and access hardening via Entra ID Conditional Access, and centralised logging and alerting. This configuration protects the organisation against phishing, spoofing, business email compromise, and mail delivery issues.

3. Scope

This configuration applies to all users, mailboxes, and domains within the Microsoft 365 tenant. It covers:

- DNS-level email authentication (SPF, DKIM, DMARC)
- Microsoft Defender for Office 365 threat protection policies
- Entra ID (Azure AD) Conditional Access policies for email access
- Audit logging, SIEM integration, and security alerting
- User awareness training and incident response procedures

4. Configuration Details

4.1 Email Authentication Protocols (Anti-Spoofing)

SPF (Sender Policy Framework)

Setting	Value
Record Type	TXT
Purpose	Authorises mail servers permitted to send on behalf of the domain
Single Provider Record	v=spf1 include:spf.protection.outlook.com -all
Multiple Provider Record	v=spf1 include:spf.protection.outlook.com include:mailchimp.com -all
TTL	1 Hour

DKIM (DomainKeys Identified Mail)

Setting	Value
Record Type	CNAME (x2)
Purpose	Cryptographically signs outbound mail to verify sender authenticity
Selector 1 Name	selector1._domainkey.<yourdomain>.com

Setting	Value
Selector 1 Target	selector1-<yourdomain>-com._domainkey.<initial>.onmicrosoft.com
Selector 2 Name	selector2._domainkey.<yourdomain>.com
Selector 2 Target	selector2-<yourdomain>-com._domainkey.<initial>.onmicrosoft.com
Activation Path	Microsoft Defender Portal > Email & Collaboration > DKIM > Enable signing

DMARC (Domain-Based Message Authentication, Reporting, and Conformance)

Setting	Value
Record Type	TXT
Purpose	Instructs receiving servers how to handle messages that fail SPF/DKIM
Prerequisite	SPF and DKIM must be configured first
Record Name	_dmarc.<yourdomain>.com

DMARC Policy Progression (Recommended):

Phase	Policy	Record Value	Use Case
1. Monitoring	p=none	v=DMARC1; p=none; rua=mailto:dmarc-reports@<domain>; pct=100	Initial deployment — observe without enforcement
2. Quarantine	p=quarantine	v=DMARC1; p=quarantine; rua=mailto:dmarc@<domain>; pct=100	Route failing messages to spam
3. Reject	p=reject	v=DMARC1; p=reject; rua=mailto:dmarc-failures@<domain>; pct=100	Block all failing messages

Validation: Use MXToolbox (mxtoolbox.com) to verify all DNS records after configuration.

4.2 Microsoft Defender for Office 365

Licensing Requirement: Microsoft 365 Business Premium or E5

Navigation: Microsoft 365 Defender Portal > Email & Collaboration > Policies & Rules > Threat Policies

Plan Comparison

Feature	Plan 1 (Business Premium / E5 Add-on)	Plan 2 (M365 E5 / E3 Add-on)
Safe Links	Yes	Yes
Safe Attachments	Yes	Yes
Anti-Phishing	Yes	Yes
Anti-Malware	Yes	Yes
Real-Time Detections	Yes	Yes
Quarantine & Reporting	Yes	Yes

Feature	Plan 1 (Business Premium / E5 Add-on)	Plan 2 (M365 E5 / E3 Add-on)
Threat Explorer	No	Yes
Automated Investigation & Response	No	Yes
Attack Simulation Training	No	Yes
Threat Tracking	No	Yes

Threat Policies Configured

#	Policy	Path	Key Actions
1	Anti-Phishing	Threat Policies > Anti-phishing	Enable mailbox intelligence, user/domain impersonation protection, spoof intelligence; set phishing threshold to Standard; quarantine detected messages using DefaultFullAccessPolicy
2	Anti-Malware	Threat Policies > Anti-malware	Block known malware attachments; enable zero-hour auto purge
3	Anti-Spam (Inbound)	Threat Policies > Anti-spam	Filter inbound spam with standard thresholds
4	Safe Links	Threat Policies > Safe Links	Scan URLs at time of click; rewrite malicious links
5	Safe Attachments	Threat Policies > Safe Attachments	Detonate attachments in sandbox before delivery
6	Outbound Spam Filter	Threat Policies > Anti-spam outbound	Monitor and limit outbound spam to protect sender reputation
7	Quarantine Policy	Threat Policies > Quarantine policies	Define quarantine release permissions and retention
8	Preset Security Policies	Threat Policies > Preset security policies	Apply Standard or Strict baselines across all threat policies
9	Attack Simulation Training (Plan 2)	Email & Collaboration > Attack simulation training	Run phishing simulations and security awareness campaigns

Anti-Phishing Note: Microsoft provides a default anti-phishing policy, but a custom policy should be created for whale phishing (targeting senior executives). Message actions should be set to "Quarantine the message" with DefaultFullAccessPolicy applied.

4.3 External Email Tagging

Setting	Value
Purpose	Visually flag emails from external senders to reduce social engineering risk
Navigation	Exchange Admin Center > Mail Flow > Rules > New Rule
Action	Prepend [External] to the subject line for emails originating outside the organisation

4.4 Identity and Access Hardening (Entra ID)

Licensing Requirement: Entra ID P1/P2 (included in Microsoft 365 Business Premium, E3/E5, or EMS)

Navigation: Entra ID > Protection > Conditional Access > + New Policy

Conditional Access Policies

Policy	Scope	Cloud Apps	Access Control
Require MFA for All Users	All users (exclude break-glass/admin accounts)	Office 365 / Exchange Online	Grant: Require MFA
Block Legacy Authentication	All users	All cloud apps	Client apps: Other clients, Exchange ActiveSync > Grant: Block access

Risk-Based Access Policies (Requires Entra ID P2)

Policy	Trigger	Action
User Risk Policy	High risk detected	Block or require MFA
Sign-In Risk Policy	Medium/High risk detected	Require MFA or block

4.5 Logs, SIEMs, and Alerts

#	Component	Purpose	Navigation
1	Audit Log Search (Purview)	Track user and admin activities	Microsoft Purview Portal > Audit > Start Recording
2	Mailbox Audit Logging	Monitor mailbox access and actions	Exchange Admin Center > Compliance Management > Auditing > Enable
3	Azure AD Diagnostic Settings	Forward logs to SIEM or storage	Entra ID > Diagnostic Settings > + Add Diagnostic Setting
4	SIEM Integration (Optional)	Centralise security event monitoring	Export via Event Hub / Log Analytics; connect Azure Sentinel or third-party SIEM
5	Security Alerts	Notifications for malware, phishing, policy violations	Microsoft 365 Defender Portal > Settings > Alerts > Manage Alerts
6	Admin Role Change Alerts	Detect unauthorised privilege changes	Entra ID > Monitoring > Alerts
7	Sign-In and Audit Log Review	Monitor login activity and audit trails	Sign-ins: Entra ID > Monitoring > Sign-ins; Audits: Purview Portal > Audit > Search

4.6 User Awareness and Incident Response

Training: Regular user training on phishing and safe practices, including social engineering simulations via Attack Simulation Training (Plan 2).

Monitoring: Review Microsoft 365 audit logs, unified audit logs, and Microsoft Defender Dashboard alerts on a regular cadence.

Backup: Implement third-party backup for M365 (e.g., Veeam or Barracuda). Ensure email archives are searchable and immutable for compliance requirements.

5. Dependencies

- Microsoft 365 Business Premium, E3, or E5 licensing

- Entra ID P1/P2 for Conditional Access and risk-based policies
- DNS provider access for SPF, DKIM, and DMARC record management
- Microsoft Defender for Office 365 Plan 1 or Plan 2
- Optional: Azure Sentinel or third-party SIEM for centralised log analysis
- Optional: EasyDMARC or equivalent for DMARC report parsing

6. Impact

- Enforcing SPF, DKIM, and DMARC significantly reduces the risk of domain spoofing and improves email deliverability to external recipients.
- Defender for Office 365 policies provide real-time protection against phishing, malware, and malicious URLs/attachments before they reach end users.
- Conditional Access policies prevent unauthorised access via legacy protocols and enforce MFA across all user sessions.
- Centralised audit logging and alerting enable rapid detection and response to security incidents.

7. Risks and Considerations

- **DMARC enforcement must be phased.** Starting with p=reject immediately can cause legitimate mail to be blocked. Always begin with p=none, monitor reports, then progress to quarantine and reject.
- **Legacy authentication blocking** may disrupt older applications or devices that do not support modern authentication. Audit legacy auth usage before enforcement.
- **Safe Links URL rewriting** may cause confusion for users who inspect links before clicking. User communication is recommended before rollout.
- **Attack Simulation Training** is only available with Defender Plan 2. Organisations on Plan 1 should explore third-party phishing simulation tools.
- **Third-party backup** is essential. Microsoft 365 does not provide point-in-time mailbox recovery beyond its native retention policies. Deleted items and compliance data may be unrecoverable without a dedicated backup solution.
- **DNS propagation** for SPF, DKIM, and DMARC records may take 24–48 hours. Plan changes during low-traffic windows.

8. Notes

- Features marked as auto-configured by Microsoft (Safe Links, Safe Attachments, Anti-Phishing, Anti-Spam, Anti-Malware) ship with default policies, but custom policies are recommended for granular control.
- Organisations using third-party antivirus/email gateway solutions should consider integration with Defender for Office 365 rather than running standalone.
- DMARC report parsing via EasyDMARC (easydmarc.com) simplifies aggregate report analysis and is available on a free tier.
- All configurations should be validated in a test environment or report-only mode before production enforcement.